

•



- [Single Sign-On](#)
- Configuring Keycloak

On this page

Was this page helpful? 

Configuring Keycloak

This page describes how to integrate Keycloak as the Identity Provider (IdP) into the Pulse environments. The integration is tested for Keycloak version 16.1.1. Take this into consideration when following this guide and the official Keycloak documentation.

Feedzai uses Keycloak to provide single sign-on (SSO) across its products: Pulse, Case-Manager (CM) and SAR Manager (SARM).

In Feedzai deployments, Keycloak is not used for user management, only for session management and the authentication protocol layer. Instead, users are authenticated and fetched from a federated Identity Provider.

The authentication request/response calls follow the standard [SAML](#) (for Pulse and CM) and [OIDC Authorization Code Flow](#) (for Pulse and SARM).

The following diagram shows how Feedzai products connect to Keycloak and where relevant information for single sign-on is stored.

Installing Keycloak¹

Refer to the official Keycloak guide for installation instructions. In Feedzai Cloud, Keycloak is configured in Standalone Clustered Mode for high-availability and with frequent database backups for an added layer of data loss protection. Consider these options for on-premise deployments.

After successfully starting Keycloak, create a new realm as described [here](#), from now on referred to as REALM_NAME.

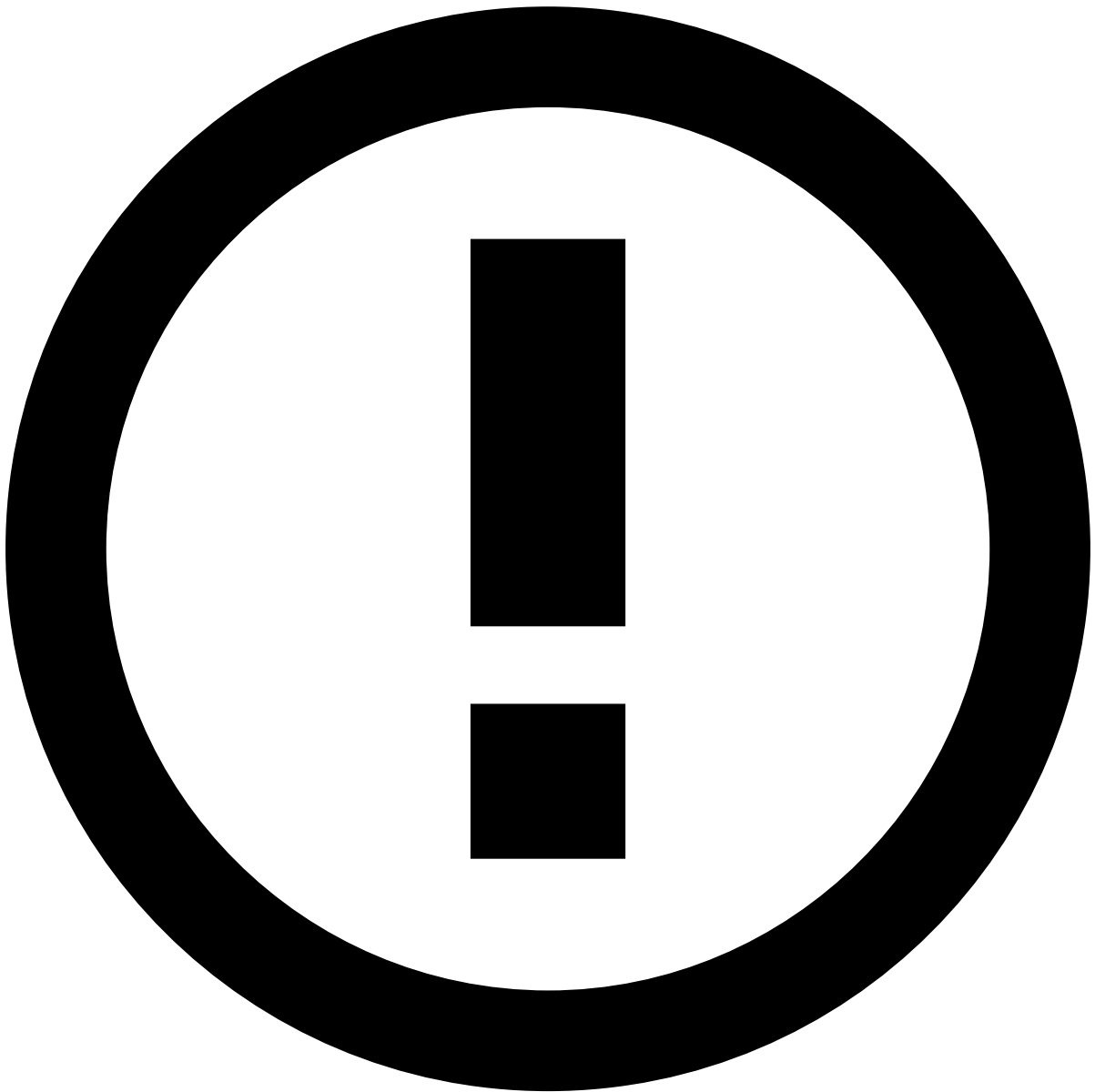
Federating an Identity Provider²

For customers that have an IdP available, Keycloak should be configured to federate user management and authentication to that IdP. Keycloak has out-of-the-box support for configuring federation using Security Assertion Markup Language (SAML) and OpenID Connect (OIDC). Multiple Social login providers can also be configured. Refer to [chapter 12](#) of the Keycloak Server Administration Guide for specific configurations.

Keycloak can be configured to transparently redirect to the federated IdP by setting an Action in the Browser Flow for the Identity Provider Redirector as explained in [this section](#) of the Keycloak documentation.

Connecting Feedzai products to Keycloak³

In Feedzai Cloud, products are configured out-of-the-box for a seamless single sign-on experience. For on-premise deployments each product must be individually configured to connect to Keycloak.



info

Note that all URLs mentioned in this document are the ones visible externally to the cluster, not internal ones. These authentication protocols work at the browser level.

The settings below include `{VARIABLES}` and `<manual instructions>` that need to be **replaced with the actual values**.

Pulse real-time scoring[ⓘ]

Keycloak Configuration[ⓘ]

To configure Keycloak to accept Pulse connections, complete the following steps:

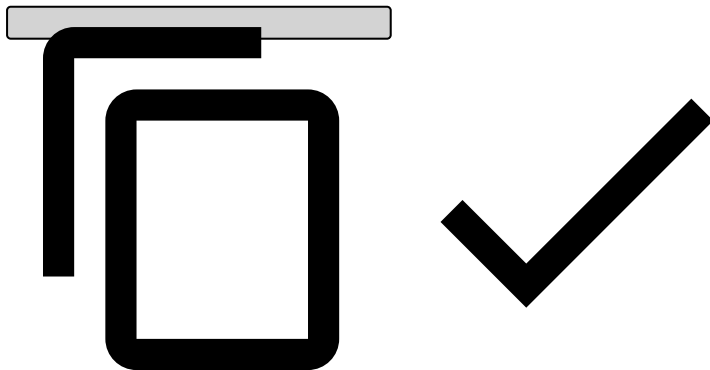
1. Create a new SAML client where the Client ID is the HTTPS URL of the real-time scoring Pulse environment (from now on referred as `PULSE_SCORING_URL`). Before saving, do the following changes to the default configuration:
 1. Turn on Sign Assertions

2. Set SAML Signature Key Name to `NONE`
3. Set Valid Redirect URIs to `{PULSE_SCORING_URL}/*`
4. Set Base URL to `{PULSE_SCORING_URL}`
5. Set Logout Service Redirect Binding URL to `{PULSE_SCORING_URL}/pulseviews/api/sessions/samlso/logout`
2. Save the client and go to the Mappers tab to configure how the user roles are propagated.
3. Create a new mapper of type User Attribute:
 1. Set SAML Attribute Name to `User.roles`.
 2. Set SAML Attribute NameFormat to `Basic`.
 3. Set User Attribute to `roles`.
4. Save the mapper.

Pulse properties

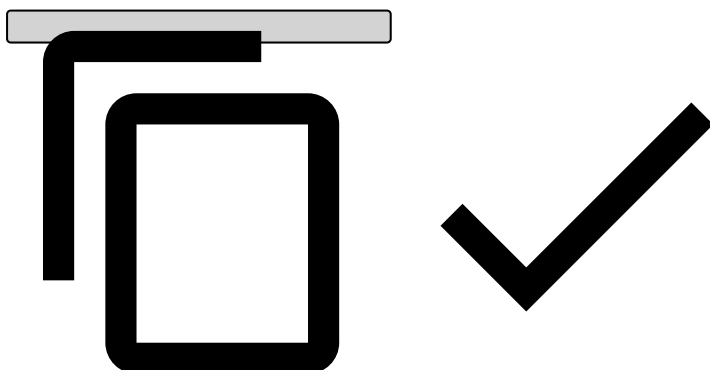
Create the following properties to configure Pulse to connect to Keycloak for SSO.

```
pulse.manager.services.core.security.authplugin.filter.samlso.enabled=true
pulse.manager.services.core.security.authplugin.filter.samlso.idp.entityId=https://
{KEYCLOAK_HOSTNAME}/auth/realms/{REALM_NAME}
pulse.manager.services.core.security.authplugin.filter.samlso.idp.sso=https://
{KEYCLOAK_HOSTNAME}/auth/realms/{REALM_NAME}/protocol/saml
pulse.manager.services.core.security.authplugin.filter.samlso.idp.slo=https://
{KEYCLOAK_HOSTNAME}/auth/realms/{REALM_NAME}/protocol/saml
pulse.manager.services.core.security.authplugin.filter.samlso.idp.x509cert=<Copy the Keycloak
realm certificate from the Realm Settings Keys tab>
pulse.manager.services.core.security.authplugin.filter.samlso.security.authnRequestsSigned=true
pulse.manager.services.core.security.authplugin.filter.samlso.security.wantAssertionsSigned=true
pulse.manager.services.core.security.authplugin.filter.samlso.sp.privateKey=<Follow Appendix A
of this page to use the private key from Keycloak client SAML Keys>
pulse.manager.services.core.security.authplugin.filter.samlso.sp.x509cert=<Copy the certificate
from Keycloak client SAML Keys>
```



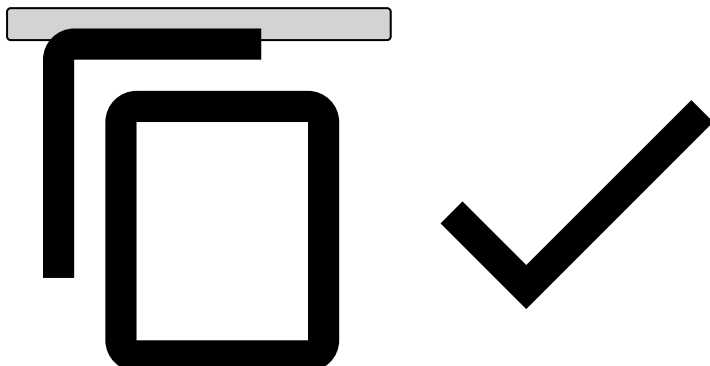
If Pulse is behind an SSL termination proxy, also add the following property:

```
pulse.manager.services.core.security.authplugin.filter.samlso.sp.forceHttps=true
```



The real-time scoring Pulse environment works as a SAML proxy for CM. Create the following properties to configure this proxy behavior. These properties do not apply to the Data Science environment of Pulse.

```
pulse.manager.services.core.security.authplugin.proxy.samlso.cm.privateKey=<Follow Appendix A to use the private key from CM Keycloak client SAML Keys>
pulse.manager.services.core.security.authplugin.proxy.samlso.cm.x509cert=<Copy the certificate from CM Keycloak client SAML Keys>
```



Data science environment

Keycloak configuration

Follow the same instructions to create a SAML client as described in the [Pulse Real-time Scoring](#) section of this page, adjusting the URL for the Pulse Data Science environment.

Pulse properties

Configure the same properties as described in the [Pulse Real-time Scoring](#) section of this page, adjusting the SAML Keys for the Pulse Data Science client created in Keycloak and excluding the CM proxying properties.

Case Manager

Keycloak Configuration

Follow the same instructions to create a SAML client as described in the [Pulse Real-time Scoring](#) section of this page, adjusting the URL for Case Manager.

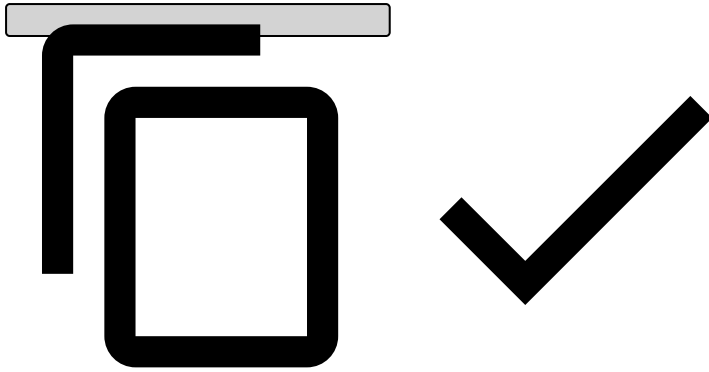
The property for the Logout Service Redirect Binding URL in CM is different from Pulse, the correct URL to use is `{CASE_MANAGER_URL}/api/session/saml-logout`.

Case Manager Configuration

The CM configuration is simpler because it uses the real-time scoring Pulse environment as its SAML proxy.

Merge the following JSON settings in `{CASE_MANAGER_INSTALL}/conf/config.json` replacing `CASE_MANAGER_URL` with the correct value:

```
{
  "cm": {
    "url": "{CASE_MANAGER_URL}"
  },
  "pulse": {
    "sso_saml_auth": true
  }
}
```



SAR Manager[®]

Keycloak Configuration[®]

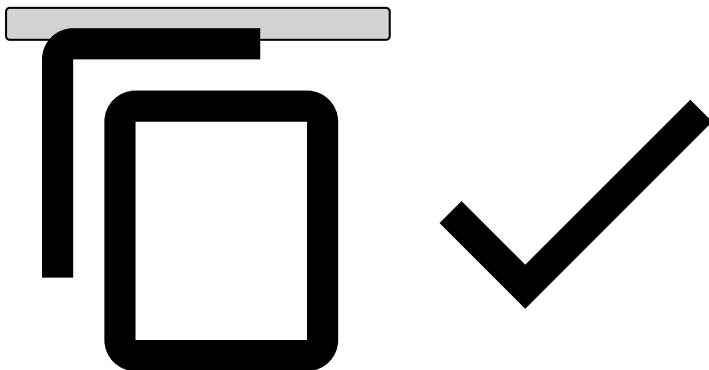
To configure Keycloak to accept connections from SAR Manager, complete the following steps:

1. Create a new openid-connect client with Client ID SARM (in this case the name doesn't need to match the SARM URL). Before saving, do the following changes to the default configuration:
 1. Set Access Type to confidential.
 2. Turn on Authorization Enabled.
 3. Set Valid Redirect URIs to `{SARM_URL}/*`
 4. Set Web Origins to `{SARM_URL}`
2. Save the client and go to the Mappers tab to configure how the user roles are propagated.
3. Create a new mapper of type User Attribute:
 1. Set User Attribute to roles.
 2. Set Token Claim Name to roles
 3. Turn on Multivalued
4. Save the mapper.

SARM Configuration[®]

Merge the following top-level YAML settings in the `{SARM_INSTALL}/config/sarm.yaml` :

```
auth:
  oidcJwkUrl: {KEYCLOAK_URL}/auth/realms/{REALM_NAME}/protocol/openid-connect/certs
  oidcDiscoveryUri: {KEYCLOAK_URL}/auth/realms/{REALM_NAME}/.well-known/openid-configuration
  oidcClientId: sarm
  oidcClientSecret: {SECRET} // Copy the secret from SARM Keycloak client Credentials tab
  oidcCallbackUrl: {SARM_URL}/auth/callback
```



Testing the integration[®]

Single sign-on should now be working. When a user logs in into one of the Feedzai products and then navigates to another one, no further login should be required.

If it is not working as expected, check the logs for both Keycloak and the affected Feedzai product for troubleshooting error messages.

For single logout to work properly, the Federated Identity Provider must support this feature and must be specifically configured to do so.

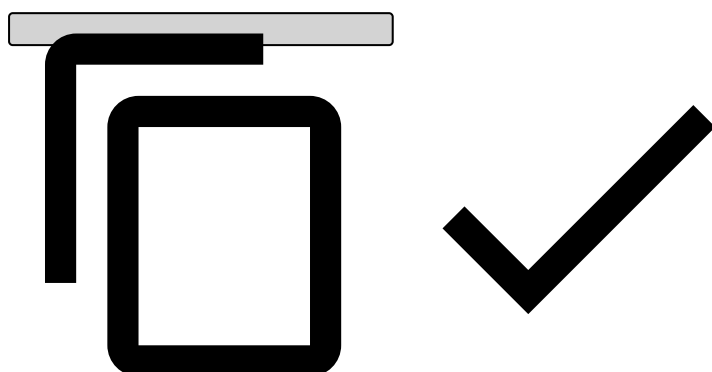
Security hardening🔒🔒

Secrets (such as the OIDC client secret) are shown in clear text in the Keycloak's Admin UI and are also stored in clear text in Keycloak's database. Because of this, it is recommended to restrict access to Keycloak Admin UI as [described here](#) and make sure that the database is only accessible from Keycloak nodes and access is granted only to authorized accounts. Note that the OIDC client secret is also stored in clear text in SARM configuration so this configuration file should also be protected with appropriate permissions.

Appendix A - Convert Private Key Format🔒🔒

To use the private key from Keycloak SAML client in Pulse, it needs to be converted to PKCS#8. Copy the private key and save in file `pk.rsa` and run the following Linux command:

```
paste -d'\n' <(echo "-----BEGIN RSA PRIVATE KEY-----") \
pk.rsa <(echo "-----END RSA PRIVATE KEY-----") | \
fold -w64 | openssl pkcs8 -topk8 -nocrypt | \
sed '1d;$d' | tr -d '\n'
```



If Pulse is configured to use a secret to encrypt sensitive configuration properties, the private key must be encrypted before setting the property.

Copy the resulting output and use it to set the private key Pulse property. Delete the `pk.rsa` file because it's no longer necessary.